

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (Grype 0.114.0 + Syft 1.45.1) · Generated 2026-06-24 · Source: `pom.xml` · Branch: `fix/depscan-20260624-060629`

Summary — Post-Remediation

Metric	Before	After
Total CVEs found	17	4
CRITICAL (Log4Shell)	2	0 ✓
HIGH	3	1
MEDIUM	2	3
LOW	1	0
Outdated dependencies	5	0
License violations	1	1 (MAJOR_REVIEW)
Supply-chain alerts	3	0 ✓

Cleared in this run

Dependency	Old → New	CVEs Resolved	CVSS
org.apache.logging.log4j:log4j-core	2.14.1 → 2.17.1	CVE-2021-44228 (Log4Shell), CVE-2021-45046	10.0, 9.0
org.apache.logging.log4j:log4j-api	2.14.1 → 2.17.1	CVE-2021-44228, CVE-2021-45046	10.0, 9.0
com.fasterxml.jackson.core:jackson-databind	2.9.8 → 2.15.4	CVE-2019-12384, CVE-2020-36518, CVE-2019-14379, CVE-2022-42003	9.8, 7.5
commons-io:commons-io	2.4 → 2.14.0	CVE-2024-47554	7.5
org.apache.commons:commons-lang3	3.4 → 3.18.0	CVE-2025-48924	6.5
com.google.guava:guava	24.1.1-jre → 33.4.8-jre	CVE-2020-8908, CVE-2018-10237	5.9
com.fastxml.jackson.core:jackson-databind	REMOVED	SC-001 typosquat supply-chain finding	n/a
http://insecure-mirror.example.net/maven2	REMOVED	SC-002 untrusted HTTP repo	n/a

Remaining findings (require human action)

Dependency	Version	Finding	CVSS	Severity	Action Required
mysql:mysql-connector-java	8.0.30	GHSA-m6vm-37g8-gqvh + GPL-2.0 license	8.3	HIGH	Replace driver — see MAJOR_REVIEW issue
org.apache.logging.log4j:log4j-core	2.17.1	GHSA-3pxv-7cmr-fjr4	medium	MEDIUM	Upgrade to 2.25.4 (next batch)

org.apache.logging.log4j:log4j-core	2.17.1	GHSA-vc5p-v9hr-52mj	medium	MEDIUM	Upgrade to 2.25.3 (next batch)
org.apache.logging.log4j:log4j-core	2.17.1	GHSA-6hg6-v5c8-fphq	medium	MEDIUM	Upgrade to 2.25.4 (next batch)

Supply-chain alerts — All cleared

- CLEARED — SC-001 Typosquatted dependency** `com.fastxml.jackson.core:jackson-databind:2.9.8` removed from `pom.xml`.
- CLEARED — SC-002 Untrusted HTTP repository** `http://insecure-mirror.example.net/maven2` removed from `pom.xml`.
- CLEARED — SC-003 GPL-2.0 license violation** on `mysql:mysql-connector-java` — flagged as MAJOR_REVIEW (requires human-driven driver replacement; see tracking issue).

Machine-readable source: `depscan-report.json` . Generated by the *Dependency & Supply-Chain Plugin* — Stage 3 Auto-Remediation. Source SHA: `61ed8c3` .